DEV-02 · Device Compliance & Configuration Baseline

What "compliant" means as a testable list — settled before Conditional Access starts enforcing it.

Field	Value
Document ID	DEV-02
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 3 — Expert Services designs the baseline; Tier 2 applies and remediates.
Review cycle	Every six months while co-management is live, then annually.

1. Purpose

"Compliant" has to mean something specific before Conditional Access can require it. This document is that definition: a testable list of conditions a device must meet, per device class, with the rollout sequence that gets the estate there without locking anybody out.

2. The lesson this document is built on

> **Plenty of IT teams learn this once, expensively.**
>
> A common example is a phishing-resistant MFA rollout that breaks access and leaves people stuck in an MFA setup loop, because a control was enforced against a population that could not yet satisfy it (ACC-03 §11).
>
> Device compliance has exactly the same shape and a larger blast radius. A Conditional Access policy requiring a compliant device, applied before the estate is compliant, does not produce a warning. It produces an organization that cannot sign in.
>
> So section 5 is deliberately slow, and the order in it is not negotiable: define, measure, report-only, remediate, then enforce. Enforcement is the last step and it follows evidence rather than a date.

3. The baseline

A device is compliant when every line below is true. Each is chosen because it is measurable from the management platform without asking anybody.

#	Condition	Why	Grace
1	Enrolled in Intune and checked in within the last 14 days	A device that has not reported cannot be assessed at all. Silent devices are where escrow gaps come from.	—
2	Entra joined with the expected join type for its class	Required for BitLocker escrow and for Windows Hello for Business.	—
3	Disk encrypted, with the recovery key escrowed in Entra	DEV-03. Encryption without a recoverable key is a data-destruction mechanism, not a control.	7 days
4	Operating system at or above the minimum supported build	Below it, security updates are not being received at all.	30 days
5	Security updates applied within the defined window	DEV-13. Patch currency is the single largest determinant of endpoint risk.	14 days
6	Endpoint protection active, healthy, and reporting	An agent installed but not reporting is worse than none, because it looks like coverage.	3 days
7	Firewall enabled	Baseline hygiene.	3 days
8	No standing local administrator beyond the DEV-12 standard	Standing local admin can disable every condition above it on this list.	30 days
9	Secure Boot enabled where the hardware supports it	Protects the boot chain the other controls assume.	30 days
10	Screen lock enabled with a maximum idle timeout	The control that matters in a shared building.	7 days

Ten conditions is deliberate. A baseline of forty settings cannot be explained to a user whose device has failed it, and a compliance failure nobody can explain becomes a ticket that Tier 2 cannot close.

4. By device class

Class	Baseline	Variation
Staff laptop and desktop	All ten.	The reference case.
Loaner	All ten, verified before every issue.	DEV-05 §3 adds a functional check on top of compliance.
Shared and training-room devices	All ten, except that the screen-lock timeout is longer during scheduled sessions.	Provisional pending DEV-06.
Conference room and kiosk	All ten, with a longer timeout and no interactive user.	Compliance is assessed against the device, not a person.
macOS	Equivalents of 1–7 and 10. FileVault replaces BitLocker; local admin and Secure Boot equivalents are recorded as gaps.	Provisional pending DEV-09. The gap list IS the DEV-09 specification.

Class	Baseline	Variation
Personally-owned	Not assessed by this document.	DEV-07. A personal device is never enrolled under DEV-01.

5. Rolling it out

1. Publish the baseline. Tier 2 and the service desk must be able to explain any failure before any user experiences one.
2. Measure. Run the compliance policy in monitoring mode across the estate and produce the three-number position: compliant, non-compliant with reasons, and never checked in. The third number is the one that will surprise people.
3. Remediate the estate against the measured position, condition by condition, worst first. Encryption and escrow lead, per DEV-03.
4. Chase the silent devices individually. They will not remediate themselves and they will not appear as failures — they simply will not appear.
5. Run the Conditional Access policy in report-only for at least ten business days over a pilot group, then over the whole estate. Read the would-be-blocked report every day of it.
6. Confirm break-glass accounts are excluded, and test that exclusion before enforcement (ACC-07 §6).
7. Enforce by wave, by device class, smallest and best-understood first. Not by date.
8. Keep the report-only evidence. It is what justifies the enforcement decision if anything goes wrong.

6. What non-compliance does, and what the user sees

Stage	Effect	What the person is told
Within grace	Nothing blocked. The device is marked non-compliant and the user is notified.	A specific, plain message: which condition, what will happen if it is not fixed, by when, and what to do. Never a generic compliance warning.
Grace expired, monitoring mode	Still nothing blocked. Reported to Tier 2 for outreach.	A second notice, and Tier 2 contacts them.
Grace expired, enforcement live	Access to organization resources blocked until compliant.	A message naming the condition and a route to fix it — self-service where possible, the service desk otherwise.

> **The message matters as much as the policy**
> “Your device is not compliant” tells somebody nothing they can act on, and produces a ticket. “Your laptop has not installed updates since 3 July — restart it, or contact the service desk” resolves itself. Tier 2 should be able to answer, for any device, which of the ten conditions failed and what fixes it. Where they cannot, the baseline is too complex (§3).

7. Grace periods and exceptions

- Grace periods are per condition, per §3, and start when the device first fails rather than when the policy was created.
- A device that cannot meet a condition for a genuine technical reason — specialist lab hardware, an instrument controller — gets a recorded exception with an owner, a compensating control and an expiry.
- Exceptions are approved by Tier 4, reviewed quarterly, and counted. A rising exception count means the baseline is wrong, not that the estate is unusual.
- There is no exception for convenience, seniority or "I need it for a presentation tomorrow". Those are grace-period conversations.

8. Co-management — two sources of truth

While Configuration Manager and Intune both manage parts of the estate, compliance signals can come from either, and they can disagree.

- Intune is the authority for compliance state. Where the two disagree, Intune is what Conditional Access reads and therefore what matters.
- Which workload sits where is recorded per workload, not assumed (DEV-01 §3).
- A device that appears compliant in Configuration Manager and non-compliant in Intune is not a reporting error. It is a device that will be blocked, and it needs resolving before enforcement.
- Reconcile the two inventories before step 5 of §5. A device in one and not the other is the most likely source of an enforcement surprise.

9. Service levels

Activity	Commitment (per GOV-06)
Device blocked by compliance enforcement	P2 — 4 coverage hours. Somebody cannot work.
Remediation of a named condition	P3, or self-service where the condition allows.
Exception request	P3 to Tier 4 — 5 coverage days.
Estate compliance report	Monthly, by Tier 3.
A condition failing across many devices at once	P1 at Tier 3. That is a policy fault, not many device faults.

10. Measurement

- Compliant / non-compliant / never-checked-in, monthly. Always three numbers.
- Non-compliance by condition — which of the ten is actually driving the number.
- Devices in grace, and devices past grace.
- Active exceptions, with age. Old exceptions are policy debt.
- Compliance-related tickets per week after enforcement, against the pre-enforcement baseline.

11. Records

Record	Held in	Retention
The baseline as approved, with version	This document	Life of the standard
Report-only evidence before each enforcement wave	Project record	Life of migration + 2 years
Exceptions: device, condition, reason, compensating control, expiry, approver	Tier 4 register	Life of the exception + 3 years
Monthly compliance position	GOV-06 monthly pack	3 years

12. Related documents

ID	Title	Relationship
DEV-01	Device Enrollment & Lifecycle	Exit criterion 4 is compliance against this baseline.
DEV-03	Disk Encryption & BitLocker Recovery Keys	Condition 3, and the first remediation priority.
DEV-12	Local Administrator Rights on Endpoints	Condition 8.
DEV-13	Patch, Update & Maintenance Window Standard	Conditions 4 and 5.
DEV-14	Endpoint Security Agent & MDR Escalation	Condition 6.
DEV-09 / DEV-06	macOS / shared-device standards	The provisional rows of §4.
ACC-03	MFA Enrollment	§2 — the same failure mode, and a common one.
ACC-07	Privileged & Administrative Account Standard	Break-glass exclusion, §5 step 6.
GOV-04	Change Management	Enforcement waves are changes.

Appendix A — Baseline checklist

The ten conditions. Tier 2 should be able to name the failing one for any device.

✓	Condition	Fixed by
☐	Enrolled and checked in within 14 days	Reconnect the device; chase if silent
☐	Entra joined, correct join type	Tier 2 — join required for escrow and Hello
☐	Encrypted, key escrowed in Entra	DEV-03 §6
☐	OS at or above minimum build	Feature update
☐	Security updates within window	Restart, or DEV-13

✓	Condition	Fixed by
☐	Endpoint protection active and reporting	DEV-14
☐	Firewall enabled	Policy reapply
☐	No standing local admin beyond DEV-12	DEV-12 §5
☐	Secure Boot enabled where supported	Firmware setting
☐	Screen lock with maximum idle timeout	Policy reapply

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.